

Privacy Passport: Making Customer Choice Enforceable Across AI

Incognito Unit | Concept Paper for New Telecom Ltd.

1. Deconstruction of the problem

New Telecom has encryption, Zero Trust and privacy assessments, yet cannot consistently trace customer data across AI systems and vendors or demonstrate permitted use. Combining identity, payment, location and behavioural records can expose private lives without a breach. The missing capability is continuous accountability: connecting existing safeguards to enforceable customer choices and auditable decisions.

2. Key privacy challenges

Privacy: excessive reuse, re-identification and persistent training, prompt or vendor copies. **Security:** prompt injection, training-data extraction and AI-assisted impersonation. **Ethics:** unfair fraud blocks, opaque profiling and manipulation. **Compliance:** unapproved transfers, ineffective rights handling and unclear ownership. The case's prohibition on targeting, tracking or profiling under-18s is a mandatory design constraint; an adult SIM registrant does not establish the actual user's age.

3. Proposed approach: Privacy Passport

Approve a purpose; enforce its boundaries. Map datasets, AI artefacts, vendors and processing countries. Each AI use receives a versioned passport: owner, lawful basis, permitted fields, operations, model, recipients, retention and privacy impact assessment. Bind permissions to authenticated application identity. Data services, training pipelines and an AI gateway check permissions and current customer preferences; outbound controls block unapproved destinations. Changed purposes or vendors require reassessment. Minimal, tamper-evident records link decisions to passports. The innovation connects approval, execution, withdrawal and evidence.

Demonstrate customer control. A rural customer withdraws personalized marketing through Bangla USSD. A proportionately authenticated request updates her preference; subsequent campaign dispatches and retries must check it. Suppress queued audiences and obtain vendor acknowledgements. Failed checks or missing acknowledgements suspend affected marketing; basic service and generic support continue. Send a neutral receipt safe for shared phones. App, voice and assisted channels support access, correction, portability, withdrawal and applicable deletion; sensitive disclosures require stronger verification. Separate optional marketing consent from essential service.

Protect all six applications. Support assistants use approved knowledge, customer-scoped tools, authorization outside the model, output checks and Bangla/English attack tests; raw conversations do not train general-purpose models. Fraud and churn use minimal features, explanations and subgroup error tests. Customer Operations handles urgent fraud appeals and restores service after erroneous blocks. Marketing excludes children; uncertain age receives generic offers. Network optimization uses coarse aggregates; released statistics may use differential privacy with tested utility and cumulative privacy limits. Document processing restricts identity-record access, validates extraction and removes unnecessary copies.

Make accountability operational. Business owners answer for each use; Privacy and Security can suspend unsafe processing. An executive council approves high-risk releases after independent assurance. Legal maintains PDPA/BTRC obligations and verifies overseas transfers; locally controlled sensitive processing is a design preference. Procurement requires disclosed subprocessors, reuse/training limits, dispatch-time consent checks, audit rights, incident escalation and deletion evidence. Nonconforming vendors receive no personalized campaign data. Track deletion across derived copies; address trained-model retention separately. Train employees and vendors through misuse scenarios; rehearse containment, fallback and required notifications.

4. Expected impact, delivery and evidence

Run a 90-day pilot: one authenticated support workflow, one campaign platform and one vendor. Days 1-30 map flows, assess risks and baseline outcomes/costs; days 31-60 integrate controls; days 61-90 test with customers and independently verify safeguards. Assign engineering and Customer Operations capacity alongside existing governance teams. Reuse identity, DLP and monitoring systems; fund expansion only when measured benefit justifies operating cost.

Proposed launch gates: all pilot uses/vendors assessed; no known critical leakage or authorization defect open; scripted withdrawal, child-exclusion and outage tests pass; at least 90% of a diverse 40-person pilot sample completes opt-out unaided within two minutes. Measure comprehension, complaint resolution, subgroup errors, support quality, audit effort and cost per resolved enquiry against baseline. Report sampling limitations; targets are not achieved results. Expand over 6-12 months only after review of customer harm, service quality and cost.

5. Applicability in Bangladesh

Bangla voice, USSD and assisted service extend rights beyond smartphones. Include rural, low-literacy and shared-phone users; avoid new biometrics merely for advertising. Customers gain choice and recourse; New Telecom gains traceability and reusable compliance evidence. Common vendor requirements support local telecom-fintech partnerships while limiting sharing. Demonstrate trust through respected choices and resolved complaints.

Research basis: Bangladesh PDPA 2026; NIST AI RMF / AI 600-1; OWASP prompt-injection guidance; NIST SP 800-226. Legal implementation includes commencement provisions and evolving rules.